



PUBLIC / EXTERNAL

Security Whitepaper

Quenyx vOPS HUB — v1.0.0 RC1 · Document v2.0

Document Version	2.0
Software Version	v1.0.0 RC1
Applies To	Quenyx vOPS HUB v1.0.0 RC1
Classification	Public / External
Owner	Security / vCISO
Status	Released
Last Updated	2026-06-29
Document Type	Whitepaper

REVISION HISTORY

Version	Date	Notes
1.0	2026	Initial v1 pack (through Sprint 19).
2.0	2026-06-29	Aligned to v1.0.0 RC1; QynCore internal communication; Integrations = external only.

Table of Contents

- 1. Authentication
- 2. Authorization
- 3. Workspace isolation
- 4. Module entitlements
- 5. Audit logging
- 6. AI safety
- 7. Prompt logging disabled by default
- 8. Conversation persistence disabled by default
- 9. Citation enforcement
- 10. No tenant evidence embeddings by default
- 11. Data retention considerations
- 12. Transport & configuration hardening
- 13. Risks and mitigations

19 — Security Whitepaper

Audience: Security teams, vCISO, auditors. **Scope:** The security model as implemented at Sprint 19.

1. Authentication

- **Laravel Sanctum** bearer tokens. All tenant routes are under the `auth:sanctum` middleware group.
- Public surface is limited to `GET /api/health` and **token-authenticated agent ingestion** (no user session).
- Login/registration via `/api/auth/*`; credentials hashed by Laravel's hasher.

2. Authorization

- **ProjectPolicy** enforces that the authenticated user is a **member** of the workspace before any workspace data is returned (controllers call `authorize('view', $project)`).
- Authorization failures return **403** (fail closed).

3. Workspace isolation

- The **project/workspace** is the tenant boundary. All compliance, monitoring, membership, audit, and integration data is scoped to a project and filtered by membership.

4. Module entitlements

- **Middleware-enforced:** `project.module:qynsight` (QynSight) and `project.qynshield` (QynShield/QCIF). Requests without the entitlement are rejected.
- Per-project **overrides** are explicit and **audited**.

5. Audit logging

- `audit_logs` records sensitive actions (module overrides, executive reads, copilot usage, etc.) with actor, action, and metadata. Available via `/audit-logs` for access reviews.

6. AI safety

- **Off by default:** `AI_ENABLED=false`, default provider **mock** → no external model call.
- **Deterministic-first:** rule-based reasoning gates answers before any model.
- **Citation-enforced:** no official source ⇒ no answer (anti-hallucination).
- **Provider-isolated:** only provider classes touch the model SDK; **no model name is hardcoded** (env-only). Verified by static scan.
- **Rate-limited:** named throttles on copilot, RAG, executive, and AI chat/skills routes.

7. Prompt logging disabled by default

`AI_PROMPT_LOGGING_ENABLED=false` — user/assistant prompt **content is never stored** unless explicitly enabled by an operator.

8. Conversation persistence disabled by default

`AI_CONVERSATION_PERSISTENCE_ENABLED=false` — the Copilot can answer without persisting any message content.

9. Citation enforcement

Compliance answers and Copilot responses must cite the corpus; uncited content is **excluded** by the RAG context builder and the Copilot. This makes outputs auditable and bounds AI risk.

10. No tenant evidence embeddings by default

`RAG_INDEX_TENANT_EVIDENCE=false`. RAG indexing only ever covers the approved **public corpus** revision unless an operator explicitly opts in. The vector provider runs **metadata-only** with deterministic fallback — it never fabricates similarity.

11. Data retention considerations

- Prompt/conversation content: not retained by default.
- Audit logs and operational/corpus data: retained per deployment policy; define retention windows with the customer.
- Backups: encrypt and store offsite; apply the same retention policy.

12. Transport & configuration hardening

- HTTPS in production (TLS at Nginx/LB); HTTP→HTTPS redirect.
- `APP_DEBUG=false` in production (no stack traces to users).
- CORS restricted to the frontend origin; `SANCTUM_STATEFUL_DOMAINS` set.
- `GATEWAY_INTERNAL_SECRET` shared secret between backend and gateway; deployment should fail if missing.
- Secrets via env/secrets manager; `.env` **is never committed** (verify `.gitignore`).

13. Risks and mitigations

Risk	Mitigation
Enabling real-model AI increases data-egress surface	Keep off unless needed; review prompt logging/persistence; cite-only outputs
Tenant evidence exposure via embeddings	Default off; requires explicit opt-in
Over-broad module access	Entitlement middleware + audited overrides
Credential leakage	Rotate seeded admin; secrets in manager; no secrets in logs
Misconfigured debug in prod	Checklist enforces <code>APP_DEBUG=false</code>
Verification gaps (DB/tests not run in audit sandbox)	Close on CI/CloudQuenyx before Sprint 20 (see QA report)